

INFORME DE PENTESTING

Fecha: 07/01/2026 Auditor: Samuel Perez Objetivo: Servidor Debian (IP: 192.168.64.4)
Herramienta de Auditoría: Kali Linux

1. Resumen Ejecutivo

Se ha realizado una prueba de intrusión (Pentest) de caja negra contra el servidor objetivo para evaluar su postura de seguridad actual. Durante el ejercicio, se logró identificar la topología de la red, enumerar servicios activos y explotar una vulnerabilidad de configuración web que resultó en la exposición de información sensible de la estructura del servidor. El nivel de riesgo detectado es MEDIO-ALTO, ya que la información expuesta facilita ataques posteriores más graves.

2. Metodología

El ataque simulado se dividió en tres fases:
Reconocimiento: Escaneo de red y puertos.
Enumeración: Identificación de versiones de servicios.
Explotación: Aprovechamiento de vulnerabilidades para acceder a información no pública.

3. Fase 1: Reconocimiento y Enumeración

Desde la estación de ataque (Kali Linux), se lanzó un escaneo exhaustivo utilizando la herramienta Nmap para descubrir servicios abiertos y versiones de software. Comando ejecutado:

nmap -sV -O 192.168.64.4

Hallazgos: El escaneo reveló los siguientes vectores de entrada:

Puerto 21: Servicio FTP (vsftpd 3.0.3).

Puerto 22: Servicio SSH (OpenSSH 9.2p1).

Puerto 80: Servidor Web (Apache httpd 2.4.62).

Evidencia Técnica:

Mapa

de
tres
críticos

```
root@kali: ~  
Session Acciones Editar Vista Ayuda  
[root@kali]~  
# nmap -sV -O 192.168.64.4  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-07 12:07 CET  
Nmap scan report for 192.168.64.4  
Host is up (0.0015s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))  
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).  
TCP/IP fingerprint:  
OS:SCAN(V=7.95%E=4%D=1/7%OT=21%CT=1%CU=38993%PV=Y%DS=2%DC=I%G=Y%TM=695E3EA8  
OS:=aarch64-unknown-linux-gnu)SEQ(SP=103%GCD=1%ISR=106%TI=I%CI=RI%II=I%SS  
OS:=S%TS=U)SEQ(SP=105%GCD=1%ISR=10A%TI=I%CI=RI%II=I%SS=S%TS=U)SEQ(SP=106%GC  
OS:=D=1%ISR=10A%TI=I%II=I%SS=S%TS=U)SEQ(SP=107%GCD=1%ISR=10C%TI=I%II=I%SS=S%  
OS:=TS=U)SEQ(SP=FF%GCD=1%ISR=109%TI=I%II=I%SS=S%TS=U)OPS(O1=M5B4%O2=M5B4%O3=  
OS:=M5B4%O4=M5B4%O5=M5B4%O6=M5B4)WIN(W1=FAF0%W2=FAF0%W3=FAF0%W4=FAF0%W5=FAF0  
OS:=S%W6=FAF0)ECN(R=Y%DF=N%T=81%W=FAF0%O=M5B4%CC=N%Q=)T1(R=Y%DF=N%T=81%S=0%A=  
OS:=S%F=AS%RD=0%Q=)T2(R=N)T3(R=Y%DF=N%T=81%W=FAF0%S=0%A=S%F=AS%O=M5B4%RD=0  
OS:=%Q=)T4(R=Y%DF=N%T=81%W=7FFF%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=N)T6(R=Y%DF=N%T=  
OS:=81%W=FAF0%S=0%A=S%F=AR%O=0%RD=0%Q=)T7(R=N)T8(R=Y%DF=N%T=81%W=7FFF%S=A%A=Z%F=R%O=  
OS:=%RD=0%Q=)T9(R=N)U1(R=Y%DF=N%T=81%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=I%RUCK  
OS:=G%RID=G)IE(R=Y%DF=N%T=81%CD=S)  
  
Network Distance: 2 hops  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 51.99 seconds  
[root@kali]~
```

de
superficie
ataque. Se
confirman
servicios
expuestos.

4. Fase 2: Explotación de Vulnerabilidad Web

Durante el análisis del servicio web (Puerto 80), se detectó una configuración incorrecta en el servidor Apache conocida como "Directory Listing" (Listado de Directorios activado).

4.1. Descripción del Fallo (CWE-548)

El servidor web no cuenta con un archivo índice por defecto (como index.html o index.php) en ciertos directorios, y la directiva Options Indexes está habilitada. Esto provoca que el servidor genere automáticamente una lista visible de todos los archivos y carpetas alojados.

4.2. Impacto del Negocio

Esta vulnerabilidad permite a un atacante no autenticado:

Entender la estructura interna de la aplicación.

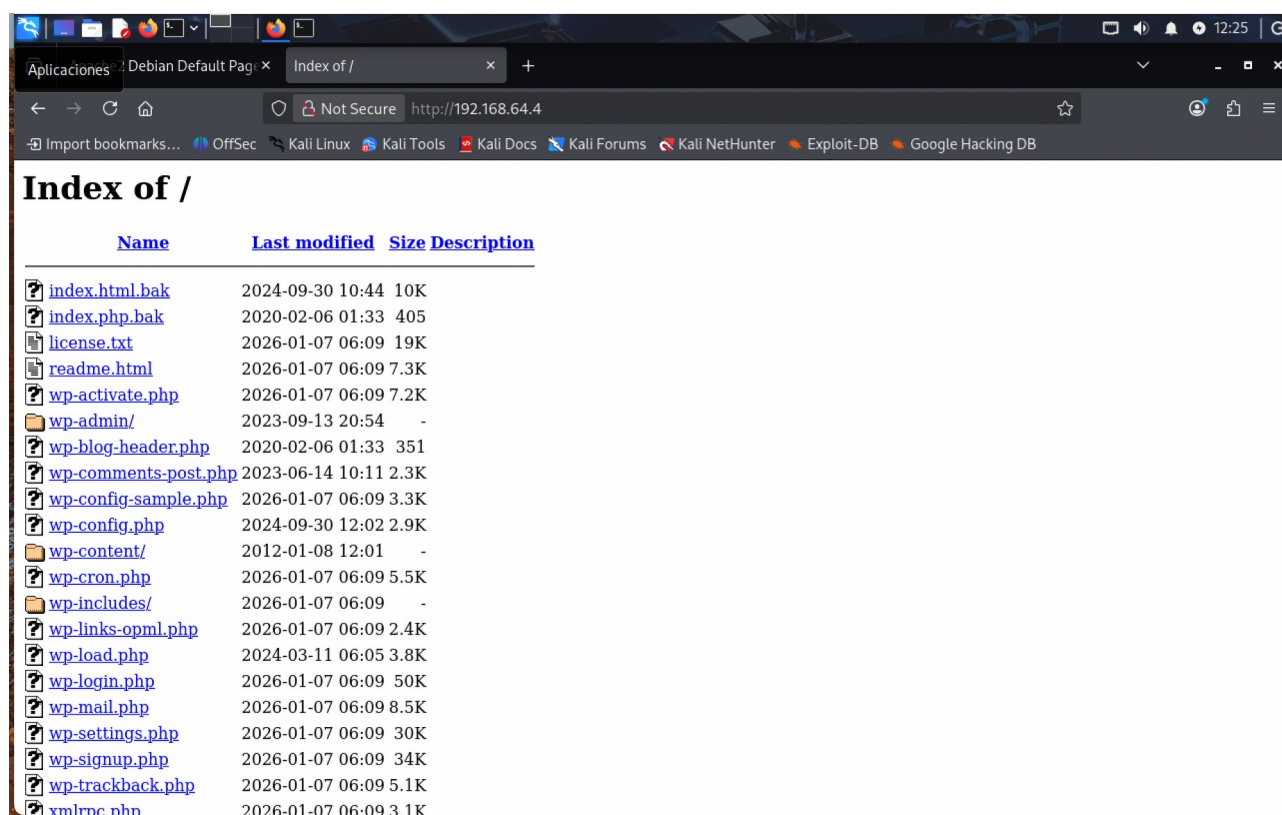
Localizar archivos de configuración ocultos, copias de seguridad (.bak) o archivos sensibles (ej: wp-config.php).

Descargar código fuente para buscar más vulnerabilidades.

4.3. Prueba de Concepto (PoC)

Al navegar a la raíz del sitio web desde el navegador de la máquina atacante, se obtuvo acceso visual directo al sistema de archivos del servidor web.

Evidencia de Explotación:



Explotación exitosa. Se visualizan archivos sensibles como 'wp-config.php' y backups.

5. Recomendaciones de Remediación

Para mitigar esta vulnerabilidad detectada en la Fase 2, se instruye al equipo de Blue Team aplicar la siguiente corrección inmediata:

Deshabilitar el Listado de Directorios: Editar el archivo de configuración de Apache (apache2.conf o .htaccess) y modificar las opciones del directorio raíz: `Options -Indexes`

Validación: Reiniciar el servicio web y verificar que el servidor devuelve un error "403 Forbidden" al intentar listar directorios sin archivo índice.